CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad	Grup	Tarih
Özgür Kerem Öncel	Gece 4/B · No: 225541072	09.11.2026

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?
   Aranacaklar: robotik/OT nöbetçi mühendisi, BT güvenlik (SOC), depo müdürü, İSG uzmanı. 1) Toplama istasyonlarını durdurup çalışanları robot alanından çıkar; robotları istasyon ve robot üzerindeki acil stoplarla fiziksel durdur (ele geçmiş filo yönetimine güvenme). 2) Şüpheli servis hesabını devre dışı bırak, VPN/jump server kanalını kes — sunucuları kapatma, resetleme. 3) Saat damgalı olay günlüğü başlat (kim, ne gördü, ne yapıldı).

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?
   Emniyet: tüm robotlar güvenli durumda (STO + fren) bekler; hız limitleri, koruma alanları ve harita imzalı referans sürümle checksum ile karşılaştırılır; izole alanda 1 robotta acil stop/durma testi. Doğrulanana kadar insanla ortak çalışma yok. Kanıt: filo denetim günlüğü, VPN/jump giriş ve oturum kayıtları, robot olay günlükleri, parametre/harita anlık görüntüleri + hash, WLAN/NAC ve güvenlik duvarı kayıtları, kamera kayıtları (salt-okunur kopya). Kapatılacak: ele geçen servis hesabı, aynı parolayı paylaşan hesaplar, WMS–filo API anahtarları/token'ları (yenilenerek).

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?
   Etkilenen ürün ve sürüm (TARQAN robot/filo yazılımı firmware), kötü niyet şüphesi/kanıtı, aktif istismar var mı, ürünün bulunduğu AB üye devletleri, ilk etki tahmini (kaç robot, emniyet etkisi), alınan ilk önlemler. Vardiya sorumlusu bunu üreticinin güvenlik ekibine (PSIRT) iletir; bildirim ENISA tek raporlama platformundan yapılır.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?
   Olay yöneticisi: zaman çizelgesi/koordinasyon. Robotik-OT: değişen parametre, emniyet etkisi, temiz konfigürasyonun geri yüklenmesi. BT güvenlik: giriş yolu ve kök neden (paylaşılan parola, MFA eksikliği), kapsam. İSG: ramak kala değerlendirmesi, yeniden başlatma onayı. Hukuk/uyum: CRA bildirimi (+gerekirse KVKK). İletişim: etkilenen markalar.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?
   Kimlik doğrulama/VPN kayıtları, tam oturum kayıtları, filo parametre değişiklik geçmişi (eski/yeni değer, kullanıcı, saat), robot olay günlükleri, güvenlik duvarı/WLAN kayıtları, kamera görüntüleri, olay günlüğü ve karar kayıtları, yeniden doğrulama test sonuçları, düzeltici önlem ve tarihi. (Not: son rapor açıkta düzeltmeden sonra 14 gün, ciddi olayda bildirimden sonra 1 ay.)

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.

Senaryonun AMR uyarlaması: servis hesabı filo yönetimindedir; robot parametreleri (bölge hız limitleri, harita) değişmiş olabilir; robotlar çalışmaya devam ediyor. Bu makinede 'resetleyip devam edelim' hem kanıtı siler hem de değiştirilmiş hız limitiyle robotu yeniden insan alanına sokabilir. Önce emniyet (insanları çıkar, robotları fiziksel durdur), hemen sonra kanıt.